Apache Dubbo 开源许可证合规检测报告

——基于 Trivy 0.76.1 的 Apache Dubbo 3.3.6 源码树扫描

学号：f25011308　　姓名：陆文雨　　班级：f250117

2026 年 10 月 22 日

一、项目介绍

Apache Dubbo 是 Apache 软件基金会（ASF）的顶级项目，定位为云原生 Java 微服务框架，提供 RPC、服务发现、流量治理、可观测性和多语言 SDK 等能力。项目采用多模块 Maven 结构，源码规模适中、第三方代码来源清晰，且同时包含 Apache-2.0、MIT 与 BSD-3-Clause 三类许可证，适合作为开源许可证合规检测与混合许可证分析的样本。

表 1 被扫描项目概况

项目	说明
项目 / 版本	Apache Dubbo 3.3.6（2025-10-17 发布，3.3.x 最新特性版本）
社区地位	ASF 顶级项目（2019 年毕业），项目许可证 Apache-2.0
项目定位	Java RPC / 微服务框架；服务发现、流量治理、可观测性、多语言 SDK
代码规模	18 个 dubbo-* 模块、116 个 pom.xml、4,758 个文件、约 19.06 MB、405,811 行 Java
扫描对象	apache-dubbo-3.3.6-src.zip（7.55 MiB），SHA-512 与 ASF 官方校验文件一致
选择理由	社区活跃、模块划分清晰；NOTICE 明确列出 Netty、t-digest、Maven Protobuf Plugin、grpc-java-contrib 等第三方代码，便于验证工具识别与人工复核

本次扫描对象为 ASF 官方发布的源码发行包，而非编译后的二进制分发包；解压后扫描其源码树。选择源码包的原因是：许可证文本、版权头、NOTICE 与构建清单都在包内，能够直接检验项目的许可证声明质量；同时，源码包不包含 Maven 解析后的第三方 JAR，因此本报告的扫描结论主要覆盖“源码树中可见的许可证”，运行时依赖风险将结合项目自带的 .licenserc.yaml 单独讨论。

项目根目录的 LICENSE 以 Apache-2.0 为主，并在文末附有 Netty、CIDRUtils（MIT）、Protocol Buffers（BSD-3-Clause）、Istio、Swagger UI、Redoc 等第三方许可证文本；NOTICE 进一步列出了 Netty、t-digest、Maven Protobuf Plugin 与 grpc-java-contrib 等来源。该结构说明 Dubbo 并非“单一 Apache-2.0”项目，而是以 Apache-2.0 为主、少量 MIT/BSD 第三方代码共存的混合许可证项目，这正是本报告分析的重点。

二、工具选型与安装

许可证合规工具可分为“源码深度扫描”“依赖/SBOM 解析”“SaaS 合规平台”三类。结合本任务对离线运行、文件级许可证证据、可复现报告和 Windows 本机执行的要求，对四款工具进行了比较，最终选择 Trivy 0.76.1。

表 2 许可证合规工具选型比较

工具	类型 / 能力	优点	不足与结论
ScanCode 32.5.0	本地 CLI / 库；文件级许可证、版权、包扫描	检测深度高，支持 JSON/HTML/SPDX/CycloneDX	本机 413 MB 许可索引加载过慢，全量扫描启动超过 10 分钟，未作为最终工具
FOSSology	Web + 数据库的团队级平台	适合组织级审计与人工复核	Windows 本地部署重，需数据库与服务器环境
ORT	流水线式依赖解析与合规策略	与构建系统结合紧密	配置复杂，依赖解析需完整构建环境
FOSSA	SaaS 合规平台	开箱即用、报告友好	需要账号/Token 与代码上传，离线不可用
Trivy 0.76.1	单文件 CLI；--license-full 扫描源码头与许可证文件	10.4 s 完成 4,758 个文件；JSON 结果含文件路径、置信度、类别	依赖解析能力弱；默认 severity 仅为策略映射，需人工解释

选择 Trivy 的关键原因是其 --license-full 模式能够直接读取源码文件头与 LICENSE/NOTICE 文本，输出“许可证名称 + 文件路径 + 置信度”的文件级证据，而不是只给出包级汇总；JSON 结果便于二次统计与复核。其不足也很明确：不解析 Maven 传递依赖，许可证 severity 默认全部映射为 LOW，不能直接等同于法律风险等级。因此本报告把工具结果与人工复核结合使用。

2.1 安装与环境

环境：Windows x64、Trivy 0.76.1（单文件可执行程序），扫描日期 2026-10-22 10:11:40—10:11:50（UTC+8）。安装过程如下：

1. 从 GitHub Releases 下载 trivy_0.76.1_windows-64bit.zip，解压得到 trivy.exe，无需管理员权限；
2. 执行 trivy --version，确认版本为 0.76.1；
3. 将 TRIVY_CACHE_DIR 指向工作区目录，避免受控账户对用户 AppData 缓存目录的写入限制；
4. 首次直接执行全量扫描时，Trivy 尝试解析 Maven POM 并访问 Maven Central，触发 HTTP 429，扫描中止；
5. 改用 --offline-scan 并跳过 **/pom.xml，只做源码级许可证扫描，扫描在 10.4 s 内完成。

表 3 安装与运行中遇到的问题

问题	现象	原因	解决
Maven Central 429	FATAL：remote Maven repository returned 429 Too Many Requests	POM 依赖解析访问远端仓库，触发限流	加 --offline-scan，并用 --skip-files "**/pom.xml" 跳过 POM
默认扫描不完整	只报告 LICENSE 与包清单，源码头未覆盖	未启用 --license-full	加 --license-full，扫描源码头与许可证文件
依赖信息缺失	输出 Number of language-specific files num=0	跳过 POM 后不做依赖解析	用 .licenserc.yaml 的 67 项声明补足运行时视角
表格输出乱码	控制台 box-drawing 字符显示为乱码	Windows 控制台代码页与 UTF-8 不一致	以 JSON 为主，另生成 UTF-8 的 HTML 整理稿

最终使用的扫描命令（PowerShell，单行）：

```
trivy fs --scanners license --license-full --offline-scan --skip-files "**/pom.xml" --format json --output output/trivy_dubbo.json data/dubbo-src/apache-dubbo-3.3.6-src
```

需要说明：跳过 pom.xml 是为了绕开 Maven 远端解析，不影响源码文件头与 LICENSE/NOTICE 的许可证识别；但这也意味着本报告不覆盖 Maven 传递依赖，后文将用 .licenserc.yaml 的 67 项依赖声明补足运行时视角。

三、工具输出的检测报告

Trivy 对 4,758 个文件、约 19.06 MB 的源码树执行扫描（跳过 116 个 pom.xml），共输出 3,981 条许可证记录，覆盖 3,979 个文件；识别出 Apache-2.0、MIT、BSD-3-Clause 三种许可证。Java 文件覆盖率为 99.97%（3,976/3,977），仅有 1 个 Java 文件未被识别。

表 4 工具输出总体统计

指标	结果
扫描对象	4,758 个文件 / 19.06 MB；3,977 个 Java 文件
许可证记录	3,981 条，覆盖 3,979 个文件（同一文件可含多条）
许可证种类	Apache-2.0（3,975 条）、MIT（4 条）、BSD-3-Clause（2 条）
Java 覆盖	3,976 / 3,977（99.97%）；仅 ProtoTypeMap.java 未被识别
识别置信度	0.917—1.000；类别均为 notice，severity 均为 LOW
扫描耗时	10.4 s（Trivy 0.76.1，Windows x64，离线扫描）

表 5 许可证分布与关键文件

SPDX 标识	检出条目	Java 文件	主要位置	核心义务
Apache-2.0	3,975	3,972	LICENSE、绝大多数 Java 文件	保留版权、LICENSE、NOTICE；修改文件需标注
MIT	4	3	FormattingTuple.java、MessageFormatter.java、CIDRUtils.java、LICENSE	保留版权与许可声明
BSD-3-Clause	2	1	Utf8Utils.java、LICENSE	保留版权、三项条件与免责声明；不得背书
未识别	—	1	ProtoTypeMap.java（人工复核为 BSD-3-Clause）	补全 BSD-3-Clause 全文并修正引用

从 Java 文件构成看，3,972 个文件为 Apache-2.0 单许可，3 个文件为 MIT 单许可（FormattingTuple.java、MessageFormatter.java、CIDRUtils.java），1 个文件为 BSD-3-Clause 单许可（Utf8Utils.java），1 个文件未识别（ProtoTypeMap.java）。这一分布与项目“Apache-2.0 为主、少量第三方兼容许可”的定位一致。

表 6 第三方关键文件复核

文件	工具结果	版权 / 来源	合规判断
ProtoTypeMap.java	无记录（0 条）	Salesforce 2019	BSD-3-Clause；工具漏检，人工补录
Utf8Utils.java	BSD-3-Clause（0.981）	Google 2008	与 LICENSE 中 Protocol Buffers BSD 文本一致
CIDRUtils.java	MIT（1.000）	Edin Dazdarevic 2013	与 LICENSE 中 MIT 文本一致
FormattingTuple / MessageFormatter	MIT（1.000）	QOS.ch 2004—2011	SLF4J 派生代码；保留文件头声明

工具原始 JSON 的典型记录如下（Utf8Utils.java，BSD-3-Clause，置信度 0.981）：

```
{
  "Name": "BSD-3-Clause",
  "FilePath": "dubbo-common/src/main/java/org/apache/dubbo/common/utils/Utf8Utils.java",
  "Confidence": 0.9812,
  "Category": "notice",
  "Severity": "LOW"
}
```

原始结果已保存为 output/trivy_dubbo.json（约 1.57 MB）；同时生成 UTF-8 的 HTML 整理稿，完整列出 3,981 条记录及文件路径，便于逐条复核。

四、检测结果分析

以下从许可证义务、兼容性、工具漏检和运行时依赖四个角度分析。需要强调：Trivy 将三类许可证的 severity 都标为 LOW，这是其默认策略映射，并不代表 BSD 的署名义务可以忽略；许可证合规的核心是“义务是否被满足”，而不是工具给出的等级。

表 7 主要许可证义务与 Dubbo 的对应关系

许可证	核心义务	Dubbo 现状	风险
Apache-2.0	提供 LICENSE；保留 NOTICE；修改文件加显著变更说明；保留专利/商标/归属声明；商标不得暗示背书	根 LICENSE、NOTICE 齐全；3,972 个 Java 文件识别为 Apache-2.0，其中 3,940 个保留 ASF 头（人工核对）	低
MIT	在副本或实质性部分中保留版权声明与许可声明	3 个 Java 文件保留 MIT 头；CIDRUtils 的 MIT 全文在 LICENSE 附录	低
BSD-3-Clause	保留版权、三项条件与免责声明；不得用作者/机构名义背书	Utf8Utils 由 LICENSE 中 Protocol Buffers BSD 文本覆盖；ProtoTypeMap 仅有名称引用，全文缺失	中
CDDL / EPL（运行时依赖）	弱 copyleft，按文件级互惠；分发需附许可证/通知，修改受控文件可能触发源码提供义务	源码扫描未覆盖；.licenserc.yaml 声明 6 项 CDDL、6 项 EPL	中

（1）整体结构清晰，强 copyleft 未出现。3,972 个 Java 文件为 Apache-2.0 单许可，3 个 MIT、1 个 BSD-3-Clause，未发现 GPL/AGPL/SSPL 等强 copyleft 许可证。Apache-2.0 与 MIT、BSD-3-Clause 均为宽松许可，彼此兼容；只要保留相应声明，Dubbo 作为 Apache-2.0 项目分发不存在许可证兼容性障碍。

（2）真正的风险点是 ProtoTypeMap.java 的 BSD-3-Clause 通知不完整。该文件头部写明 “Licensed under the BSD 3-Clause license”，并要求查看仓库根目录的 LICENSE.txt；但源码包中只有 LICENSE（无 LICENSE.txt），且 LICENSE 附录没有 Salesforce/grpc-java-contrib 的 BSD-3-Clause 全文。NOTICE 只写了版权与“licensed under the BSD 3-Clause License”，没有三项条件和免责声明。BSD-3-Clause 要求源码再分发时保留版权声明、条件列表和免责声明，因此仅靠 NOTICE 的名称引用并不充分。

（3）工具漏检恰好暴露了“名称引用”与“全文文本”的差异。Trivy 对 3,976 个 Java 文件给出结果，唯独漏掉 ProtoTypeMap.java；原因是该文件只有许可证名称和链接，没有可匹配的全文。若只依赖工具汇总，会得出“Java 覆盖率 100%、无 BSD 风险”的错误结论。这也说明许可证合规不能只看工具通过率，必须对“工具未识别”的文件做人工抽样复核。

（4）运行时依赖需要单独治理。.licenserc.yaml 声明了 67 项依赖：Apache-2.0 46 项、BSD-3-Clause 6 项、MIT 3 项、CDDL（1.0/1.1）6 项、EPL（1.0/2.0）6 项。CDDL/EPL 属于弱 copyleft，通常不要求整个项目开源，但若修改了受控文件，可能触发按文件提供源码的义务；分发二进制时还需附上相应许可证与通知。源码扫描因跳过 POM 而未覆盖这些依赖，这是本报告最重要的范围限制。

表 8 合规风险矩阵

风险项	等级	依据	建议
Salesforce BSD 通知不完整	中	ProtoTypeMap.java 仅名称引用；LICENSE 无对应全文；工具漏检	补全 BSD-3-Clause 全文，修正 LICENSE.txt 引用
CDDL/EPL 运行时依赖	中	.licenserc.yaml 声明 6 项 CDDL、6 项 EPL	生成并随包分发 THIRD-PARTY.txt；法务复核
传递依赖未扫描	中	跳过 pom.xml，未解析 Maven 依赖	发布前用 SBOM/SCA 扫描二进制分发包
Apache NOTICE / 商标	低	LICENSE、NOTICE 齐全；Apache 商标政策明确	保留 NOTICE；不暗示 ASF 背书
GPL/AGPL 等强 copyleft	低	源码树未发现	CI 设置禁止性许可证门禁

4.1 合规建议

1. 补齐 BSD-3-Clause 全文：在根目录增加 LICENSE-BSD-3-Clause.txt（或并入 LICENSE），包含 Salesforce 版权、三项条件与免责声明；同时把 ProtoTypeMap.java 的 LICENSE.txt 引用改为实际文件路径。
2. 随分发物提供完整通知：保留 LICENSE、NOTICE，并生成 THIRD-PARTY.txt；项目已有 licenseCheck.sh（Maven license 插件）可生成依赖许可证清单，应在发布流程中固化。
3. 把许可证扫描纳入 CI：每次发布执行 trivy fs --scanners license --license-full，保存 JSON 作为审计证据；对 GPL/AGPL/SSPL 设置失败门禁，对 CDDL/EPL 设置人工复核。
4. 补充 SBOM/二进制扫描：源码扫描不能替代依赖审计；建议用 CycloneDX/SPDX 生成 SBOM，并对 dubbo-all 等二进制分发包再做一次许可证扫描。
5. 建立人工复核清单：对“工具未识别”“仅有许可证名称/链接”“NOTICE 与 LICENSE 不一致”的文件逐条复核；本次的 ProtoTypeMap.java 应作为首个案例。

五、结论

Apache Dubbo 3.3.6 是一套以 Apache-2.0 为主、少量 MIT/BSD-3-Clause 第三方代码共存的微服务框架。Trivy 0.76.1 在 10.4 s 内完成 4,758 个文件的源码树扫描（跳过 116 个 pom.xml），给出 3,981 条文件级许可证记录，Java 覆盖率达 99.97%，未发现 GPL/AGPL 等强 copyleft 许可证，整体许可证结构清晰、兼容性良好。

主要合规缺口不在许可证类型，而在通知完整性：ProtoTypeMap.java 的 BSD-3-Clause 仅有名称引用，缺少全文；工具也因此漏检。补齐该全文、随包提供 LICENSE/NOTICE/THIRD-PARTY.txt，并对 CDDL/EPL 运行时依赖做二进制级复核后，Dubbo 的再分发合规风险可控制在较低水平。本报告也说明：许可证工具擅长“发现线索”，但“是否满足义务”仍需要人工判断。

附：主要检测产物

· output/trivy_dubbo.json：Trivy 原始 JSON（约 1.57 MB，3,981 条记录，可用于复核与二次统计）。
· output/trivy_report.html：UTF-8 可读整理稿（摘要、许可证分布与 3,981 条明细，支持关键字过滤）。
· data/apache-dubbo-3.3.6-src.zip：被扫描源码包，SHA-256 2551A403…87C3，SHA-512 与 ASF 官方校验一致。

参考资料

[1] Apache Software Foundation. Apache Dubbo. https://dubbo.apache.org/
[2] Apache Software Foundation. Apache License, Version 2.0. https://www.apache.org/licenses/LICENSE-2.0
[3] Trivy Documentation. License Scanning. https://trivy.dev/latest/docs/scanner/license/
[4] Apache Dubbo 3.3.6 Source Release. https://archive.apache.org/dist/dubbo/3.3.6/apache-dubbo-3.3.6-src.zip
[5] SPDX License List. https://spdx.org/licenses/
[6] Open Source Initiative. The 3-Clause BSD License. https://opensource.org/license/bsd-3-clause

声明：本报告仅用于课程作业的许可证合规分析，不构成法律意见。